HAICHAIN

HAICHAIN דוח הערכת סיכונים מוסדיים והגנה קריפטוגרפית

דוח בדיקת נאותות סיכונים מוסדיים V1.1 • תקן הגנה קריפטוגרפי

HAICHAIN: דוח בדיקת נאותות סיכונים מוסדיים

הוכחות מתמטיות, מידול איומים ומטריצת אימות רד-טים עבור קרנות Tier-1 וחברות ביקורת

קהל יעד

קרנות מובילות וחברות ביקורת

אבטחה קריפטוגרפית

מפתח חומרה 9 • Passkey אינוריאנטים

ליבת הפרוטוקול

HAICHAIN v1.1 • CapLeaf 223 בייטים

דוח בדיקת נאותות סיכונים מוסדיים ואבטחת קריפטוגרפיה של HAICHAIN

הוכחות מתמטיות, מידול איומים ומטריצת אימות רד-טים

קהל יעד: קרנות הון סיכון מובילות (a16z crypto, Paradigm, Sequoia), גופי משמורת מוסדיים וחברות ביקורת מובילות (OtterSec, Neodyme, Kudelski Security)
גרסת פרוטוקול: HAICHAIN Kernel v1.1 / CapLeaf v1 (סכמת Wire של 223 בייטים)
תקנים: Anchor Framework (Solana L1) + Sui Move (`AgentCap`) + Tron Rail Intent Solver

1. תקציר מנהלים ופרדיגמת אבטחה

סוכני בינה מלאכותית אוטונומיים המבצעים מיקרו-תשלומים פיננסיים מציגים משטחי תקיפה שונים מהותית מ-DeFi המופעל על ידי בני אדם: 1. **אפס השהיית מעורבות אנושית:** סוכן AI המבצע קריאות כלים עלול להיחטף באמצעות הזרקת פרומפט עקיפה (Indirect Prompt Injection) ולהנפיק אלפי שוברי תשלום בלתי מורשים בתוך שניות. 2. **פגיעות דליפת מפתחות פרטיים:** הפעלת מופעי סוכנים על גבי צמתים מבוזרים מגבירה את הסיכון לחשיפת מפתחות. 3. **התרבות סוחרים זדוניים (Sybil):** ברשת M2M פתוחה, תוקפים יכולים לרשום דומיינים חד-פעמיים כדי לעקוף מגבלות קצב.

כדי לפתור זאת ללא פגיעה במהירות תת-מילישנייה, **HAICHAIN מפרידה לחלוטין בין ביצוע תשלומים למשמורת הון**: - **סמכות ריבונית עליונה:** מפתח חומרה ביומטרי WebAuthn FIDO2 Passkey (P-256) שומר על 100% בעלות ריבונית מוחלטת על הקופה. - **בידוד הרשאות תת-סוכנים:** מפתחות Ed25519 זמניים מבודדים בארגז חול בתוך מנוע המדיניות (Policy Engine) ללא גישה למילות השחזור של הארנק. - **עוגן מרקל על הבלוקצ'יין:** סכמת עלה של 223 בייטים אוכפת 9 אינווריאנטים מתמטיים ($I_1 \dots I_9$).

2. מודל איומים פורמלי ותקרת הפסד (τ_4)

בתרחיש הקיצון שבו מפתח ה-Ed25519 של הסוכן נחשף במלואו וקיים שיתוף פעולה עם סוחר מאומת בעץ המרקל, סך הגניבה המרבי $E_{theft}(\tau)$ מוגבל באופן מתמטי קשיח:

$$E_{theft}(\tau) \le \min(B,\; K,\; W_p \cdot n(\tau, \omega_p),\; \Sigma_{i:\, m_i \in \mathcal{A}} E_i(\tau))$$

מסקנה מעשית: עבור קופה מוסדית עם יתרה של `USDT 10,000`, תקרת עלה של `USDT 50` ומגבלת קצב של `USDT 10` **לשעה**, תוקף **לא יוכל לגנוב יותר מ-`USDT 10`** לפני כניסת ההקפאה לתוקף, מה שמבטיח הגנה על `USDT 9,990` **(99.9%)** מהקרן.

3. מטריצת הקשחה ו-9 אינווריאנטים

1. **מניעת תביעה כפולה באסקרו:** פדיון חד-כיווני בלתי הפיך ($P_i \le \min(C_i, R_i)$).
2. **הגנת חשבון ATA קנוני:** מניעת ניתוב כספים לחשבונות זרים.
3. **בידוד הקפאת פאניקה (I_6):** ביטול מיידי של כל השוברים בתפוצה.
4. **השבת דמי שכירות (Lamports):** החזרה מלאה לקופה המקורית.
5. **בלימת מתקפות Sybil:** צריכה קשיחה של תקרת תקציב האב.

כל ההוראות ב- `programs/haichain-core/src/lib.rs` מצייתות ל-9 אינווריאנטים מתמטיים ($I_1 \dots I_9$).

4. טוקנומיקה ותאימות רגולטורית

- **תקן שירות טהור ללא דיבידנדים:** חסינות מלאה מפני מבחן Howey ורגולציית MiCA האירופית.

- **50% רכישה חוזרת ושריפה (Buyback & Burn):** 50% מדמי הרשת מופנים לרכישת $HAISI ושריפתו לצמיתות.
- **50% קרן רזרבה אוטונומית (CHGB):** תמיכה ביציבות ורשתות חיסול מרובות.